

FINAL PROJECT DUE July 2, 2026 by Noon

1 Directions

Given the protocol specification and scenario below, model the protocol in CPSA and state if the protocol fits the use case in the scenario and why. Then, state if either you believe the protocol satisfies the lab's security goals, or the protocol includes issues/attacks which compromise the goals.

2 Deliverables

1. A functioning CPSA model of the protocol described in the spec below. Your model should be able to be compiled and ran on any system. The shapes it produces should be the same shapes used in the following deliverables.
2. Prepare a brief 5-10 minute presentation that includes a brief description of the protocol, screenshots of the shapes your CPSA model produced, and a high-level description of your analysis. Be prepared to present this on the last day of the workshop!
3. You should also prepare a writeup, approximately one page in length, that describes the protocol, whether the protocol is a good fit for the scenario, and its adherence to security goals in the scenario. You should include some pictures of your shapes in the writeup (this will help you fill the page). You should also include a works cited for any materials that you reference. This may include the workshop slides, the CPSA manual, and any other CPSA code that you inspect. You should make an attempt to decide which assumptions make sense in this scenario and clearly state your reason for why in your write up.

3 Protocol Specification:

```
:: S, C, AS      : principal
:: N1, N2, N3,   : nonce
:: TS           : timestamp
:: L            : lifetime
:: pk, sk       : principal —> keypair

:: C -> AS       : C, S, N1
:: AS -> C       : AS, {AS, C, N1, pk(S)}sk(AS)
:: C -> S        : C, S, {C, TS, L, {N2}pk(S)}sk(C)
:: S -> AS       : S, C, N3
:: AS -> S       : AS, {AS, S, N3, pk(C)}sk(AS)
:: S -> C        : S, C, {S, cat(N2, ``1'')}pk(C)
```

Participants

1. Client C
2. Server S
3. Authentication Server AS
4. User U

The User U controls the Client C and initiates all actions performed by C .

Notation

- N_1, N_2, N_3 : fresh nonces (unique per session)
- TS : timestamp
- L : lifetime / expiration interval
- $pk(X)$: public key of principal X
- $sk(X)$: private (signing) key of principal X
- $\{M\}_{sk(X)}$: message M signed by X
- $\{M\}_{pk(X)}$: message M encrypted for X
- $cat(x, y)$: concatenation of x and y

Protocol Description

Phase 1: Client obtains Server's public key

1. The User instructs the Client C to initiate communication with AS .
2. $C \rightarrow AS : C, S, N_1$
The Client requests the public key of S , including a fresh nonce N_1 .
3. $AS \rightarrow C : AS, \{AS, C, N_1, pk(S)\}_{sk(AS)}$
The Authentication Server responds with a signed message containing the identities AS, C , the nonce N_1 , and the public key of S .
4. The User may optionally inspect the response.

Phase 2: Client initiates session with Server

5. $C \rightarrow S : C, S, \{C, TS, L, \{N_2\}_{pk(S)}\}_{sk(C)}$
The Client sends its identity, the Server's identity, and a signed payload containing a timestamp TS , a lifetime L , and a fresh nonce N_2 encrypted under $pk(S)$.

Phase 3: Server obtains Client's public key

6. $S \rightarrow AS : S, C, N_3$

The Server requests the public key of C , including a fresh nonce N_3 .

7. $AS \rightarrow S : AS, \{AS, S, N_3, pk(C)\}_{sk(AS)}$

The Authentication Server responds with a signed message containing the identities AS, S , the nonce N_3 , and the public key of C .

Phase 4: Server responds to Client

8. $S \rightarrow C : S, C, \{S, \text{cat}(N_2, "1")\}_{pk(C)}$

The Server proves possession of N_2 by decrypting it, appending the string "1", and encrypting the result under $pk(C)$.

Operational Requirements

- All nonces N_1, N_2, N_3 must be freshly generated and unique.
- Private keys $sk(X)$ must never be disclosed.
- Each principal must send all messages it is responsible for and correctly process all received messages.
- The Server S operates independently and must not delegate its authority to any other principal.

4 Scenario:

You are a Researcher in the UMBC Protocol Analysis Lab. The lab is developing a distributed storage network in which students must mutually authenticate with data storage servers.

Since many students are using the servers, pre-sharing symmetric keys across every pairing is infeasible. To manage key distribution, our lab has designed a custom protocol using an authentication server that acts as an authority on the system. The goal of this protocol is to verify the identities of both parties using public-key cryptography, establish a fresh session key, and prevent replay attacks using timestamps and lifetimes.

Before this protocol is cleared for use in the lab, the PAL Education team has assigned the lab to conduct a formal-methods analysis on it. You must determine if this design fulfills the security goals for the lab and/or if there are any attacks or flaws on the system.

5 Submission

A form will be available on the GitHub page in the [final project](#) directory.

When submitting make sure to include your CPSA model file, a write up on your work (including a works cited), and your slides. You must include your produced shapes in your write up which could be done by importing the images or the text output.

Your main references will be the manual, previous slides in the workshop, any related papers on CPSA or protocol analysis, and your partner. Please attempt to do this project without other human or AI help, besides your partner and instructors.